MITRE ATLAS | AML.CS0006 - ClearviewAI Misconfiguration

Entry Information

ID:
AML.CS0006
Type:
Case-Study
Name:
ClearviewAI Misconfiguration
URL:
https://atlas.mitre.org/studies/AML.CS0006/
Incident Date:
2020-04-16
Target:
Clearview AI facial recognition tool
Actor:
Researchers at spiderSilk

Description

Clearview AI makes a facial recognition tool that searches publicly available photos for matches. This tool has been used for investigative purposes by law enforcement agencies and other parties.

Clearview AI's source code repository, though password protected, was misconfigured to allow an arbitrary user to register an account.
This allowed an external researcher to gain access to a private code repository that contained Clearview AI production credentials, keys to cloud storage buckets containing 70K video samples, and copies of its applications and Slack tokens.
With access to training data, a bad actor has the ability to cause an arbitrary misclassification in the deployed model.
These kinds of attacks illustrate that any attempt to secure ML system should be on top of "traditional" good cybersecurity hygiene such as locking down the system with least privileges, multi-factor authentication and monitoring and auditing.

Attack Procedure:
[AML.T0021] Establish Accounts: A security researcher gained initial access to Clearview AI's private code repository via a misconfigured server setting that allowed an arbitrary user to register a valid account.
[AML.T0036] Data from Information Repositories: The private code repository contained credentials which were used to access AWS S3 cloud storage buckets, leading to the discovery of assets for the facial recognition tool, including:
- Released desktop and mobile applications
- Pre-release applications featuring new capabilities
- Slack access tokens
- Raw videos and other data
[AML.T0002] Acquire Public AI Artifacts: Adversaries could have downloaded training data and gleaned details about software, models, and capabilities from the source code and decompiled application binaries.

[AML.T0031] Erode AI Model Integrity: As a result, future application releases could have been compromised, causing degraded or malicious facial recognition capabilities.

References

- TechCrunch Article, "Security lapse exposed Clearview AI source code" — https://techcrunch.com/2020/04/16/clearview-source-code-lapse/

- Gizmodo Article, "We Found Clearview AI's Shady Face Recognition App" — https://gizmodo.com/we-found-clearview-ais-shady-face-recognition-app-1841961772

- New York Times Article, "The Secretive Company That Might End Privacy as We Know It" — https://www.nytimes.com/2020/01/18/technology/clearview-privacy-facial-recognition.html